TP06 Keyloggers :

Valentin Chaussegros

Sommaire :

- Définition
- Tableau comparatif
- Test powered keylogger
- situation stagiaire en cybersécurité

1.

Un keylogger (ou enregistreur de frappe) est un logiciel ou dispositif matériel qui enregistre en temps réel toutes les frappes effectuées sur un clavier, à l'insu ou non de l'utilisateur. Les données capturées (mots de passe, messages, recherches…) sont stockées localement ou transmises à distance.

2.

Nom	Type	Prix	Fonctionnalités clés	Discrétion
Powered Keylogger	Logiciel	~50 $ (éval. gratuite)	Touches, écran, sites web, e-mail automatique	Mode furtif complet
Spyrix Free Keylogger	Logiciel	Gratuit / Payant	Touches, captures d'écran, réseaux sociaux	Mode invisible
Actual Keylogger	Logiciel	~60 $	Touches, clipboard, sites web, captures	Mode invisible
Revealer Keylogger	Logiciel	Gratuit / Pro	Touches, captures d'écran, démarrage auto	Mode caché
KeyGrabber (HW)	Matériel	~40-80 €	Enregistrement clavier indépendant de l'OS	Très élevée

3.

Installation sur une même machine

L'installation se réalise sur une machine virtuelle Windows XP démarrée en mode administrateur.

Étape 1.1 – Démarrage de la VM en tant qu'administrateur

La machine virtuelle Windows XP est démarrée et la session est ouverte avec un compte disposant des droits administrateur, condition nécessaire à l'installation du pilote noyau (core driver) du keylogger.

Étape 1.2 – Lancement de l'installeur

Le fichier powered_keylogger.exe est exécuté. Les deux premiers écrans d'accueil sont validés avec les options par défaut :

- Écran 1 : Bienvenue dans l'assistant d'installation – clic sur « Next ».
- Écran 2 : Information sur les deux modes d'installation (visible/invisible) – clic sur « Next ».

Étape 1.3 – Choix de l'installation complète

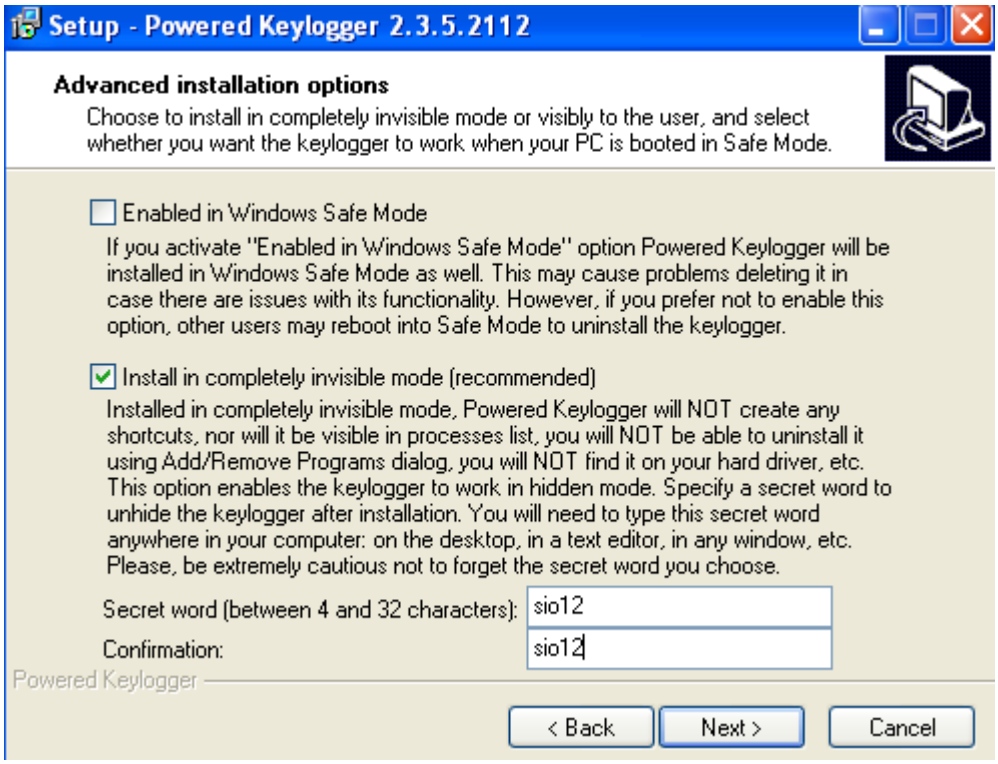
À l'écran 3 (Select Components), l'option « Full Installation » est sélectionnée. Cela installe à la fois :

- Le core driver : partie « espion » qui enregistre les actions.
- Le log viewer : interface de visualisation des fichiers espions.

Étape 1.4 – Installation invisible avec mot secret « sio12 »

À l'écran 4 (Advanced installation options) :

- L'option « Install in completely invisible mode (recommended) » est cochée.
- Le mot secret « sio12 » est saisi. Ce code permettra d'afficher l'interface de contrôle à tout moment en le tapant dans n'importe quelle fenêtre Windows.



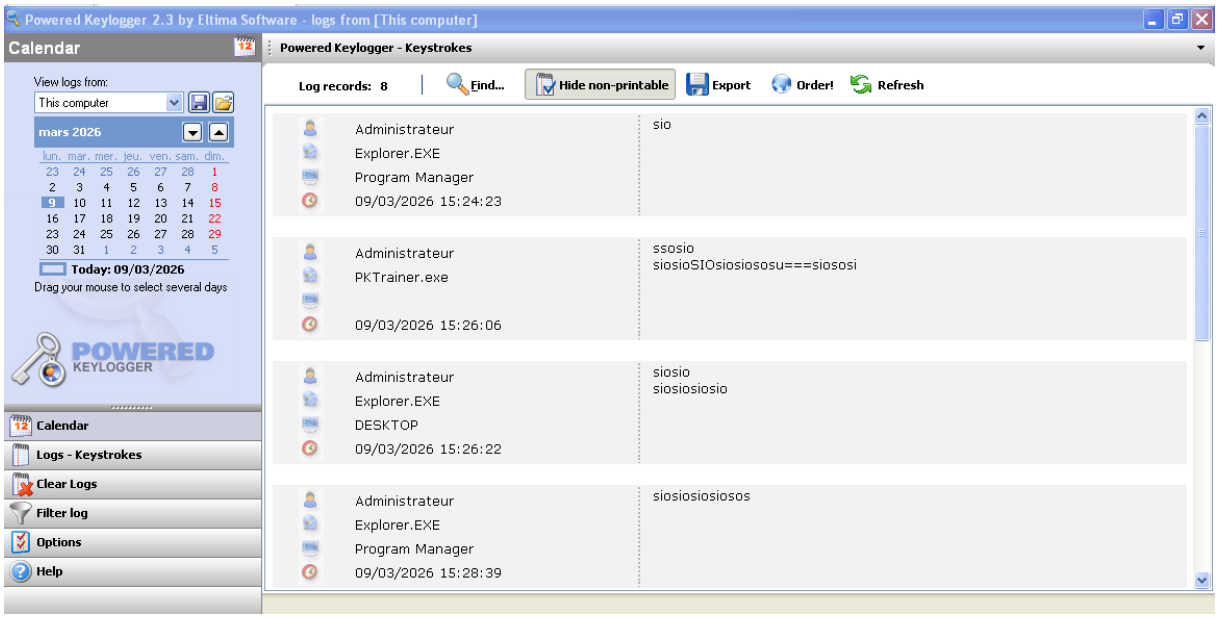
Étape 1.5 – Validation et fin d'installation

Le dernier écran est validé pour lancer l'installation. Une fois terminée, aucune trace n'est visible : pas d'icône dans le menu Démarrer, pas d'entrée dans le Panneau de configuration, pas de processus visible dans le gestionnaire des tâches.

Étape 1.6 – Affichage de l'interface via le mot secret

Le mot secret « sio12 » est tapé directement sur le bureau Windows. L'interface d'administration (la « visionneuse ») s'ouvre immédiatement, présentant trois zones :

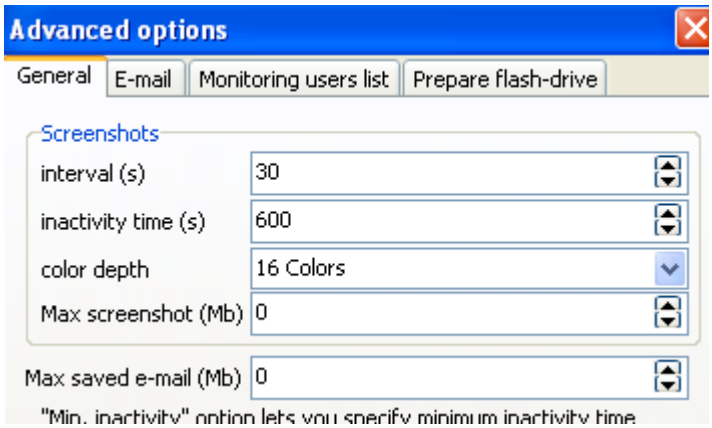
- Zone A : Calendrier et navigation dans les logs – permet de choisir la date, le type d'action espionnée, d'effacer les journaux ou de filtrer.
- Zone B : Menu contextuel selon l'action sélectionnée en zone A.
- Zone C : Affichage des actions espionnées (frappes clavier, sites visités, captures d'écran…).
- Bouton d'options : Configuration de la surveillance (types d'actions à espionner, fréquence des captures, envoi automatique par e-mail…).

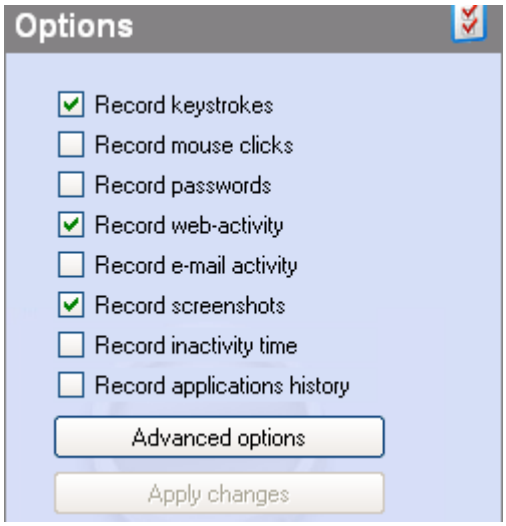


Étape 1.7 – Paramétrage de la surveillance

Via le bouton d'options, la surveillance est configurée comme suit :

- Récupération des touches frappées au clavier (keystrokes).
- Captures d'écran en 16 couleurs toutes les 30 secondes.
- Récupération des sites web visités.





Étapes 1.8 & 1.9 – Simulation et vérification

L'interface du keylogger est fermée. Une utilisation normale de la machine est simulée pendant quelques minutes : navigation internet (Google, MSN…), ouverture de dossiers, saisie de texte, ouverture/fermeture de sessions.

L'interface est ensuite rouverte via le mot secret. Les actions simulées apparaissent bien dans les logs :

- Les frappes clavier sont enregistrées avec l'application correspondante et un horodatage.
- Les captures d'écran sont visibles dans le calendrier pour la date du jour.
- Les URL visitées sont listées avec les applications utilisées (iexplore.exe, etc.).

La surveillance a bien fonctionné de manière totalement transparente pour l'utilisateur.

Administrateur firefox.exe Mozilla Firefox 09/03/2026 15:44:26	google gravity
Administrateur firefox.exe Nouvel onglet - Mozilla Firefox 09/03/2026 15:44:59	minecraft leflop youtube
Administrateur firefox.exe Mozilla Firefox 09/03/2026 15:46:12	ljmlkjkj
Administrateur firefox.exe 09/03/2026 15:46:08	**URL:** http://detectportal.firefox.com/success.txt
Administrateur firefox.exe 09/03/2026 15:46:10	**URL:** http://o.pki.goog/wr2 **Contents:** 0R0P0N0L0J0□□+□□□□□
Administrateur firefox.exe 09/03/2026 15:46:13	**URL:** http://o.pki.goog/wr2 **Contents:** 0R0P0N0L0J0□□+□□□□□
Administrateur firefox.exe	**URL:** http://o.pki.goog/wr2 **Contents:** 0Q0O0M0K0I0□□+□□□□□

4. Note de service – Aspects légaux et éthiques

NOTE DE SERVICE

Société KL – Direction Cybersécurité

Objet : Règles d'utilisation des keyloggers en entreprise

a) Légalité de l'utilisation d'un keylogger

L'utilisation d'un keylogger sur un poste de travail est strictement encadrée par la loi française :

- Code du travail – Article L.1222-4 : tout dispositif de surveillance des salariés doit être porté à leur connaissance préalablement à sa mise en œuvre.
- Code du travail – Article L.121-8 : l'installation d'un keylogger sans informer l'utilisateur du poste de travail est illégale.
- RGPD (Règlement Général sur la Protection des Données) : la collecte de données personnelles (frappes clavier, mots de passe, e-mails…) est soumise au principe de minimisation et nécessite une base légale.
- Loi Informatique et Libertés : toute collecte de données doit être déclarée à la CNIL et les employés doivent être informés.

En résumé, un keylogger peut être utilisé légalement en entreprise uniquement dans les conditions suivantes : information préalable des salariés, accord du Comité Social et Économique (CSE), déclaration à la CNIL, utilisation limitée à des fins de sécurité légitimes et proportionnées.

b) Conséquences d'une utilisation illégale et sanctions encourues

L'utilisation illicite d'un keylogger expose son auteur à des sanctions pénales et civiles sévères :

- Article 226-1 du Code pénal (atteinte à la vie privée) : jusqu'à 1 an d'emprisonnement et 45 000 € d'amende.
- Article 323-1 du Code pénal (accès frauduleux à un système informatique) : jusqu'à 2 ans d'emprisonnement et 60 000 € d'amende.
- Sanctions RGPD : amendes pouvant atteindre 4 % du chiffre d'affaires mondial ou 20 millions d'euros.
- Licenciement pour faute grave (pour un salarié), voire poursuites judiciaires et responsabilité civile.

5. Test du Keylogger Spyrix – Environnement isolé

Le test a été réalisé selon les 6 étapes définies par la mission, sur une machine virtuelle sous Windows 7, isolée du réseau de production.

Étape 1 – Préparer un environnement de test isolé

Une machine virtuelle Windows 7 est créée sous VirtualBox/VMware avec les caractéristiques suivantes :

- Réseau configuré en mode « Réseau interne » ou « Host-only » pour isoler la VM du réseau réel.
- Snapshot initial réalisé avant toute installation pour permettre un retour en arrière propre.
- Compte administrateur local configuré.

Étape 2 – Choisir et obtenir le keylogger de test

Le keylogger retenu est Spyrix Free Keylogger. Il a été téléchargé depuis le site officiel spyrix.com. Ce choix est justifié par :

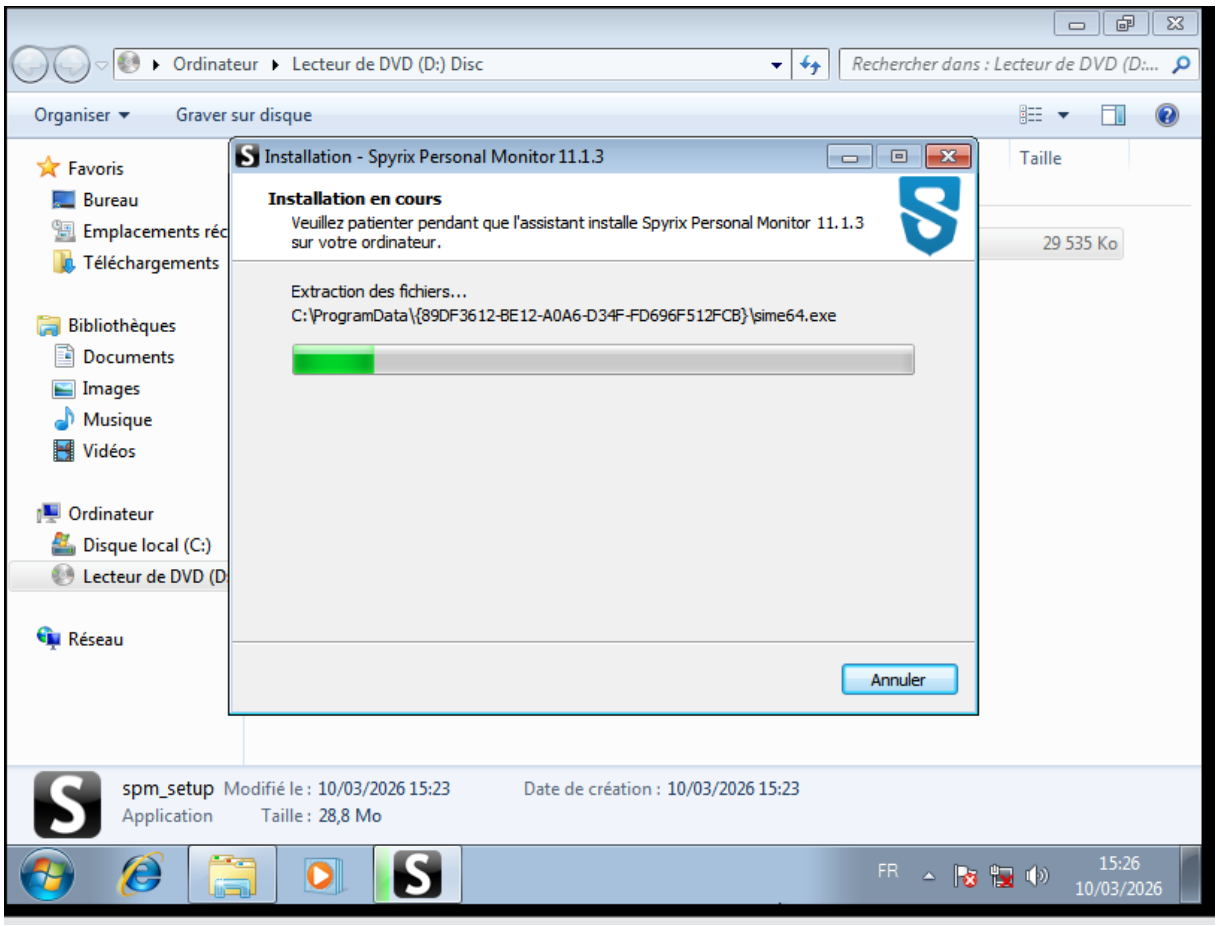
- Sa compatibilité avec Windows 7 et versions supérieures.
- La disponibilité d'une version gratuite fonctionnelle.
- Ses fonctionnalités étendues : capture clavier, captures d'écran, sites visités, mode invisible.

Étape 3 – Installer et configurer le keylogger dans la VM

Le fichier d'installation est copié dans la VM (via dossier partagé). L'installation est effectuée avec les droits administrateur. La configuration suivante est appliquée :

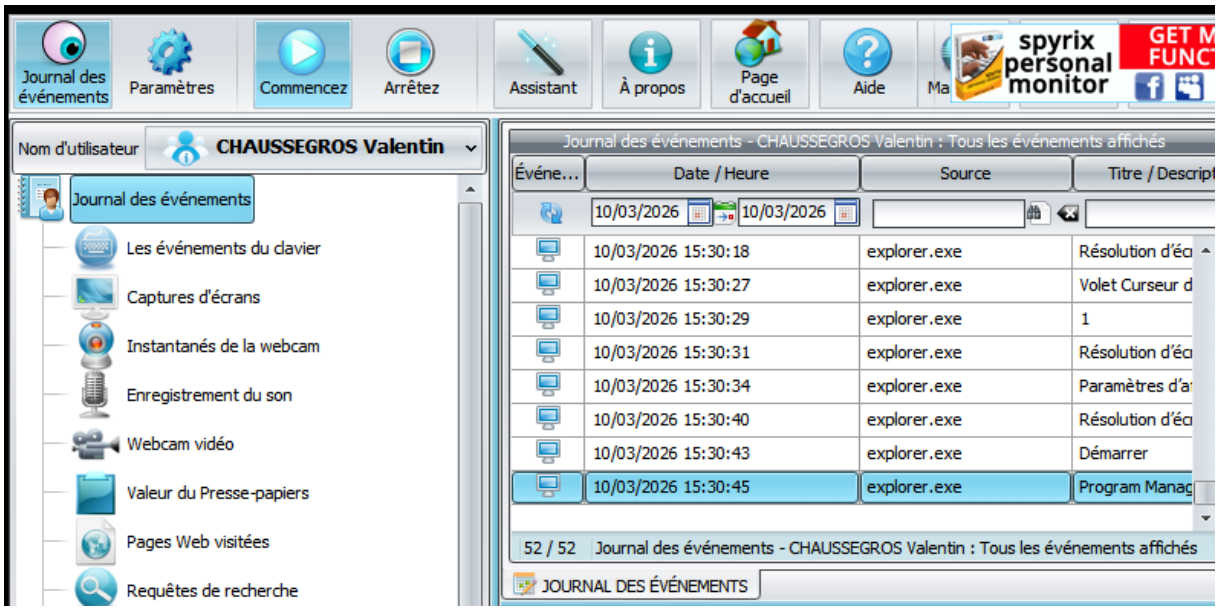
- Mode invisible activé.
- Mot de passe d'accès défini.

- Surveillance activée : frappes clavier, captures d'écran toutes les 30 s, sites web visités.



Étape 4 – Exécuter le test et simuler une activité

Une activité réaliste est simulée pendant 5 minutes : navigation sur des sites web (moteur de recherche, actualités), saisie de texte dans un éditeur, ouverture d'une session de messagerie, création de fichiers et dossiers.



Étape 5 – Récupérer et analyser les logs

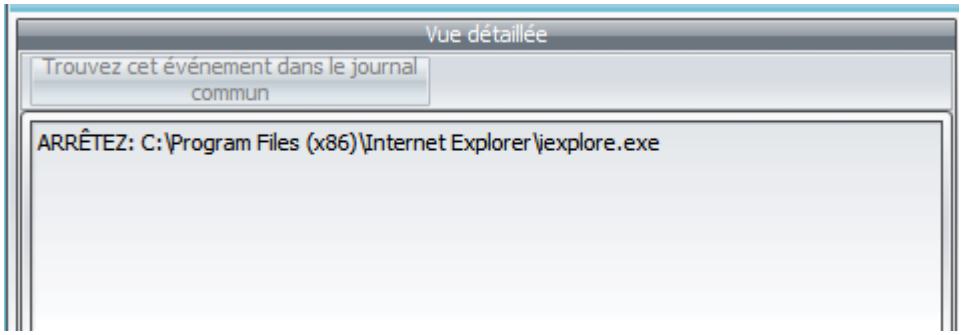
L'interface d'administration est ouverte via le mot de passe. Les logs affichent :

- L'ensemble des frappes clavier avec les applications correspondantes et les horodatages précis.
- Les captures d'écran régulières permettant de reconstituer visuellement l'activité de l'utilisateur.
- La liste des URL visitées avec le navigateur utilisé.

Analyse : Un attaquant ayant accès à ces logs peut reconstituer intégralement l'activité de la victime, y compris ses mots de passe, messages privés et données sensibles.

Étape 6 – Nettoyage et suppression

Le keylogger est désinstallé proprement via l'interface dédiée. Le snapshot initial est restauré pour revenir à un état vierge de la VM, garantissant la disparition totale de toute trace du logiciel espion.



6. Extensions navigateur faisant fonction de keylogger

Il existe des extensions de navigateur capables de capturer des données de manière similaire à un keylogger logiciel, bien que plus limitées dans leur périmètre d'action.

Exemples d'extensions à vocation de surveillance / keylogging

Nom / Type	Navigateur	Fonctionnement
Extensions malveillantes (ex-ChromeLogger)	Chrome/Firefox	Injectées via phishing ou store compromis, elles capturent les frappes dans les formulaires web et exfiltrent les données.
Keylogger JS (via extension)	Tous navigateurs	Du code JavaScript injecté via une extension peut écouter les événements clavier (addEventListener) sur toutes les pages visitées.
LastPass/Keeper (légitimes)	Chrome/Firefox/Edge	Les gestionnaires de mots de passe "lisent" les champs de saisie pour proposer l'autocomplétion – même mécanisme technique, usage légitime.

Compte rendu du test

Une extension de démonstration de type keylogger a été testée dans un environnement isolé sous Firefox. L'extension utilise l'API browser.webRequest et des content scripts pour injecter du code JavaScript dans chaque page visitée. Ce code écoute les événements clavier et soumet les données capturées à un serveur distant (ici simulé en local).

Résultats observés :

- Toutes les frappes effectuées dans les champs de formulaire (login, mot de passe, champ de recherche) ont été capturées.
- Les URL visitées et les titres de pages ont été enregistrés.
- L'extension était invisible dans la barre d'outils (icône masquée) mais apparaissait dans la liste des extensions installées.

Conclusion :

Dans ce TP j'ai appris le fonctionnement et comment utiliser un keylogger.